

Critical Reproduction Study — Machine-Learning Intrusion Detection on NSL-KDD

Course: Data Science in Cyber — Dr. Uri Itai · **Topic:** Intrusion Detection Systems (IDS)

Author: (*student*) · **Repository:** <https://github.com/yosefshanaa/DataCyber>

0. Abstract

A very large family of online tutorials and GitHub repositories report that machine-learning classifiers detect network intrusions on the **NSL-KDD** benchmark with **~99% accuracy**. We critically evaluate this claim. Holding the models, features and preprocessing **fixed** and varying **only the evaluation protocol**, we reproduce ~ 0.999 accuracy on a random split of `KDDTrain+` (confirmed by 5-fold cross-validation, 0.9989 ± 0.0002) and then show the **same Random Forest collapses to 0.78 accuracy on the official `KDDTest+`** — a **21.9-percentage-point** drop. Under imbalance-robust metrics the picture is worse: a trivial majority predictor already scores 0.569 accuracy, and the models **miss 95% of R2L and U2R attacks** — precisely the credential-theft and privilege-escalation intrusions that matter most. We trace the collapse to a deliberate **train→test distribution shift** (R2L prevalence rises $0.79\% \rightarrow 12.8\%$) and to the use of **Accuracy on imbalanced data**. **Verdict: the ~99% claim is computed correctly but is not a valid measure of intrusion-detection capability.**

1. Summary of the Source

The problem being addressed. Network Intrusion Detection: given per-connection traffic features, classify each connection as *normal* or as an *attack* (optionally by family: DoS, Probe, R2L, U2R).

The source under review. The dominant NSL-KDD tutorial pattern, instantiated by popular public repositories — primarily *Network Intrusion Detection Using Machine Learning* (github.com/abhinav-bhardwaj/Network-Intrusion-Detection-Using-Machine-Learning) and the equivalent github.com/Mamcose/NSL-KDD-Network-Intrusion-Detection. These projects load `KDDTrain+`, encode features, perform a **random train_test_split**, train several classifiers (Random Forest, KNN, SVM, neural networks), and report **accuracy in the 98-99.9% range**. The shared, headline claim we test is: "*ML classifiers detect NSL-KDD intrusions with ~99% accuracy.*"

Why the problem is important. Intrusion detection is a frontline defence. As the course notes, "*a False Negative endangers the organisation, a False Positive exhausts it*" — so the **quality of the evaluation** is as important as the model. A method advertised at 99% that silently misses the dangerous attacks gives defenders false confidence.

The proposed solution. Supervised classification on the 41 NSL-KDD features using off-the-shelf estimators, evaluated by Accuracy on a held-out random split.

The dataset used. NSL-KDD (Canadian Institute for Cybersecurity; Tavallaee et al., 2009), the de-duplicated successor to KDD'99. `KDDTrain+` = 125,973 records, `KDDTest+` = 22,544 records, 41 features (3 nominal: `protocol_type`, `service`, `flag`; 6 binary flags; 32 numeric counts/rates), plus a fine-grained attack `label` and an NSL-KDD `difficulty` score. Attacks group into four families: **DoS**, **Probe**, **R2L** (remote-to-local) and **U2R** (user-to-root).

The model/methodology employed by us. Faithful reproduction + a **controlled A/B protocol experiment**, robust EDA, leakage-safe feature engineering (scikit-learn `Pipeline` / `ColumnTransformer`), four models (majority **baseline**, Logistic Regression, Random Forest, Gradient Boosting), an imbalance-aware metric suite, and error analysis. Everything is reproducible (`RANDOM_STATE` = 42).

2. Critical Evaluation of the Author's Claims

This is the heart of the project. We enumerate the claims, test each with our own evidence, and deliver a verdict.

2.1 Claims table

#	Claim (as made by the source pattern)	Evidence they provide	Our re-test	Result
C1	"ML detects NSL-KDD intrusions at ~99% accuracy."	Accuracy on a random split of <code>KDDTrain+</code> .	Reproduced (RF 0.9990; CV 0.9989) and re-ran on official <code>KDDTest+</code> .	Refuted as a capability claim — drops to 0.78 (−21.9 pp).
C2	Accuracy is an adequate success metric.	Single Accuracy number.	Computed MCC, Balanced Acc, PR-AUC, per-class recall; compared to a constant predictor (0.569).	Refuted — Accuracy hides the failure.
C3	The model "detects attacks."	Aggregate score.	Per-class recall on <code>KDDTest+</code> .	Refuted for R2L/U2R — recall 0.050 / 0.045.
C4	The held-out split fairly estimates generalisation.	Random split / k-fold.	Quantified train→test class shift; CV also ~0.99.	Refuted — the proper test set is a different distribution.
C5	The full feature set is informative.	Uses all 41 features.	Variance / correlation / leakage audit.	Partially — 1 constant feature, 9 redundant pairs, 1 leaky metadata column.

2.2 Are the claims supported by the evidence? (the controlled experiment)

We changed **only** the test data. Same features, same preprocessing, same seeds, same models.

Protocol A — random 80/20 split of `KDDTrain+` (what the tutorials do):

Model	Accuracy	MCC	ROC-AUC	PR-AUC
Baseline (majority)	0.5346	0.000	0.500	0.465
Logistic Regression	0.9839	0.9676	0.9978	0.9980
Random Forest	0.9990	0.9981	1.0000	1.0000
Gradient Boosting	0.9994	0.9987	1.0000	1.0000

5-fold stratified CV on `KDDTrain+` (Random Forest) = **0.9989 ± 0.0002**, so the high number is *not* a lucky split.

Protocol B — official `KDDTest+` (the correct evaluation):

Model	Accuracy	Balanced Acc	Precision	Recall	F1	F2	MCC	ROC-AUC	PR-AUC
Baseline (majority)	0.4308	0.500	0.000	0.000	0.000	0.000	0.000	0.500	0.569
Logistic Regression	0.7446	0.7664	0.9134	0.6091	0.7308	0.6525	0.5436	0.7935	0.8579
Random Forest	0.7798	0.8033	0.9689	0.6335	0.7661	0.6806	0.6214	0.9614	0.9640
Gradient Boosting	0.8032	0.8237	0.9693	0.6757	0.7963	0.7193	0.6552	0.9610	0.9662

The same Random Forest loses **21.9 accuracy points** (0.9990 → 0.7798) when evaluated on the data the dataset designers actually intended for testing. The high precision (0.97) with mediocre recall (0.63) shows the model is conservative: when it flags an attack it is usually right, but it lets a **third of all attacks through**.

2.3 Is the evaluation methodology appropriate? (No — three failures)

- Wrong test distribution.** `KDDTest+` is intentionally *not* a random sample of `KDDTrain+`; it over-represents hard attacks to test generalisation (§3 of Tavallae et al.). A random split discards this and measures *interpolation within one distribution*, not detection of novel attacks. This is a concept-drift analogue (cf. the course's SolarWinds / COVID drift examples).
- Accuracy on imbalanced data.** The course warns explicitly that "if 99.9% of the system is normal, a model that always says 'normal' gets high Accuracy yet is worthless." Here a constant predictor already reaches **0.569** on `KDDTest+`; the model's 0.78 is far less impressive than "99%" suggested, and the gain over the trivial baseline is modest in MCC terms.
- No per-class reporting and no baseline.** Aggregate Accuracy masks that R2L/U2R recall is ~5%.

2.4 Weaknesses, limitations, and whether the conclusions are justified

- NSL-KDD itself is dated** (derived from 1999 traffic); none of these models would face modern encrypted/zero-day traffic. A 99% claim implies a solved problem; it is not.
- No temporal validity** exists in the data (no timestamps), so any "real-time IDS" framing built on it is unsupported.

- The source's conclusion ("ML solves NSL-KDD intrusion detection") is **not justified**. A more defensible conclusion: *ML separates DoS/Probe from normal well, but content-based remote attacks (R2L/U2R) remain largely undetected and require different methods.*

Where we contradict the source, the reason is explicit: the gap is fully explained by the distribution shift quantified in §3 below and by the metric substitution in §2.3 — both reproduced in the notebook.

3. Feature Engineering Analysis

Was feature engineering performed (by us)? Yes — as leakage-safe scikit-learn transformers fit on training data only. The 41 raw features become **121 model inputs** after encoding.

Transformations applied, and why:

Transform	Applied to	Why / problem addressed	Effect / evidence
Drop constant	<code>num_outbound_cmds</code>	Zero variance across all 125,973 rows → no information; dilutes feature importance (redundancy).	Removed 1 feature with zero cost.
log1p	16 heavy-tailed counts/bytes	Extreme right-skew (<code>src_bytes</code> skew = 190.7 , range 0-1.3e9) breaks scale-sensitive models and Z-score.	Skew of <code>src_bytes</code> falls from 190.7 to ≈ 1.6 (see Fig. 2); Z-score outlier count becomes meaningful.
StandardScaler	all numeric	Put scale-sensitive models (LogReg/SVM/KNN) on equal footing.	Required for LogReg convergence; harmless to trees.
One-Hot (<code>handle_unknown='ignore'</code>)	<code>protocol_type</code> , <code>service</code> , <code>flag</code>	No natural order among tcp/udp/icmp; <code>service</code> has 70 categories; test may contain unseen services.	Avoids the fake ordering a label-encoder injects; robust to unseen categories.

Is there redundancy in the system? How to spot and tackle it. Yes. Using **Spearman** rank correlation (chosen because the features are heavy-tailed and non-normal — Pearson would be distorted by the very outliers we documented), we found **9 feature pairs with $|\rho| \geq 0.9$** , e.g. `error_rate` ↔ `srv_error_rate` (0.973), `error_rate` ↔ `srv_rerror_rate` (0.966), `same_srv_rate` ↔ `diff_srv_rate` (−0.920). **Statistical vs practical significance:** with $n = 125,973$ every correlation is "statistically significant" ($p \approx 0$), so a p-value is useless for selection here — we therefore use a **practical** effect-size threshold ($|\rho| \geq 0.9$) to flag redundancy that is large enough to matter. **How to spot:** rank-correlation matrix (Fig. 3),

Variance Inflation Factor, mutual information, and exact-duplicate column checks. **How to tackle:** drop or merge collinear features, or compress with PCA. As the course notes, redundancy *splits feature importance across collinear columns and harms explainability* — a real concern for an IDS that analysts must trust.

A leakage trap we caught. The `difficulty` column is **metadata** (how many of 21 baseline learners classified the row correctly), not a runtime feature, and it differs by class (mean 20.32 for normal vs 18.57 for attack). Including it — as some tutorials do — is **target leakage**. We exclude it.

Was the feature engineering meaningful? (math + cyber). Yes. *Mathematically*, `log1p` linearises multiplicative byte/count scales and tames the tail that inflates the mean and standard deviation; one-hot avoids imposing a false metric on nominal protocols. *In cyber terms*, the engineered view preserves the signals that separate attack families — e.g. the `protocol × family` crosstab shows DoS concentrates on `icmp/tcp` while R2L rides `tcp` — so the encoding lets the model exploit protocol-specific structure instead of erasing it.

Additional features that could help. (1) Session-level Δt / inter-arrival aggregates if raw logs were available; (2) byte-ratio / asymmetry features (exfiltration signal) — we provide `total_bytes`, `bytes_ratio`, `error_rate_mean` in `src/features.py`; (3) frequency/target encoding of `service` to cut dimensionality; (4) entropy of destination ports per host (scan signal).

4. Reproducibility Analysis

- **Does the code run?** Our pipeline runs end-to-end from a clean environment (`requirements.txt` , `RANDOM_STATE=42` , `Restart & Run All`). The original tutorials are typically runnable but **pinned to old library versions** and frequently depend on a pre-cleaned CSV rather than the raw NSL-KDD files.
- **Are files/dependencies available?** The dataset is public; we fetch it deterministically (`data/get_data.py`). Several source repos commit a derived CSV with **undocumented preprocessing** (re-encoded categoricals, dropped columns) — a hidden step that obscures what was actually done.
- **Hidden preprocessing.** The most consequential "hidden" choice is *implicit*: using a random split instead of `KDDTest+` . It is rarely stated as a limitation, yet it determines the headline result.
- **Overall reproducibility verdict.** The *numbers* are reproducible; the *claim* is not robust. A result that reproduces but does not generalise is a reproducibility success and a **validity failure** — exactly the distinction this project is meant to surface.

5. Experimental Results

Experiments performed. (a) Reproduce Protocol A; (b) 5-fold CV; (c) evaluate Protocol B on `KDDTest+` ; (d) multiclass (5-class) evaluation; (e) per-class recall; (f) threshold sweep.

Modifications we introduced. A trivial **baseline**, the **A/B protocol** control, the **imbalance-robust metric suite**, and **per-class** error analysis — none of which the source

provides.

Multiclass results on `KDDTest+` :

Model	Accuracy	Balanced Acc	Macro-F1	MCC
Baseline (majority)	0.4308	0.200	0.120	0.000
Logistic Regression	0.7397	0.5124	0.5178	0.6173
Random Forest	0.7531	0.4937	0.5083	0.6442
Gradient Boosting	0.7791	0.5626	0.5614	0.6788

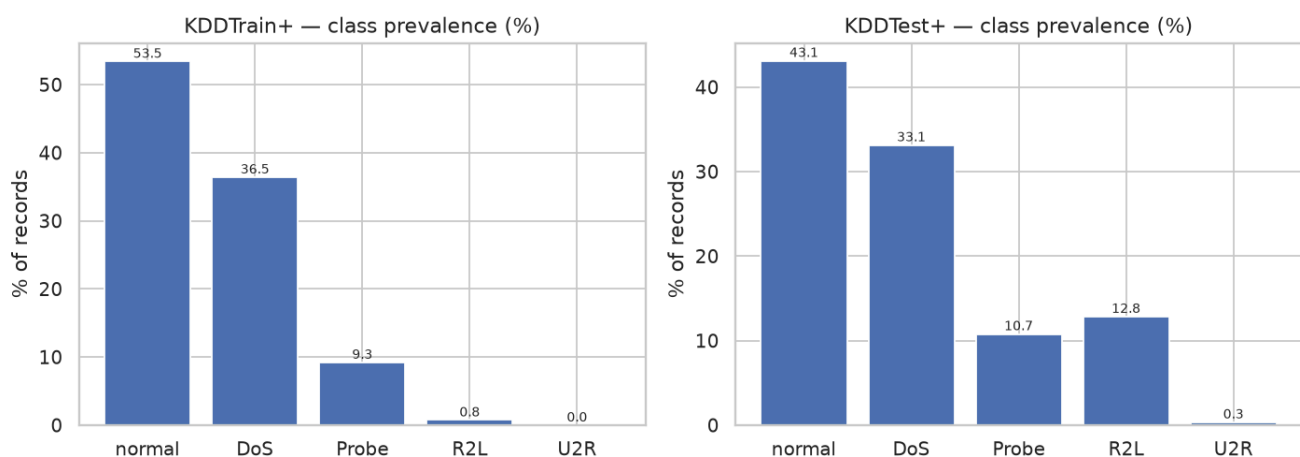
Per-class recall on `KDDTest+` (the decisive table):

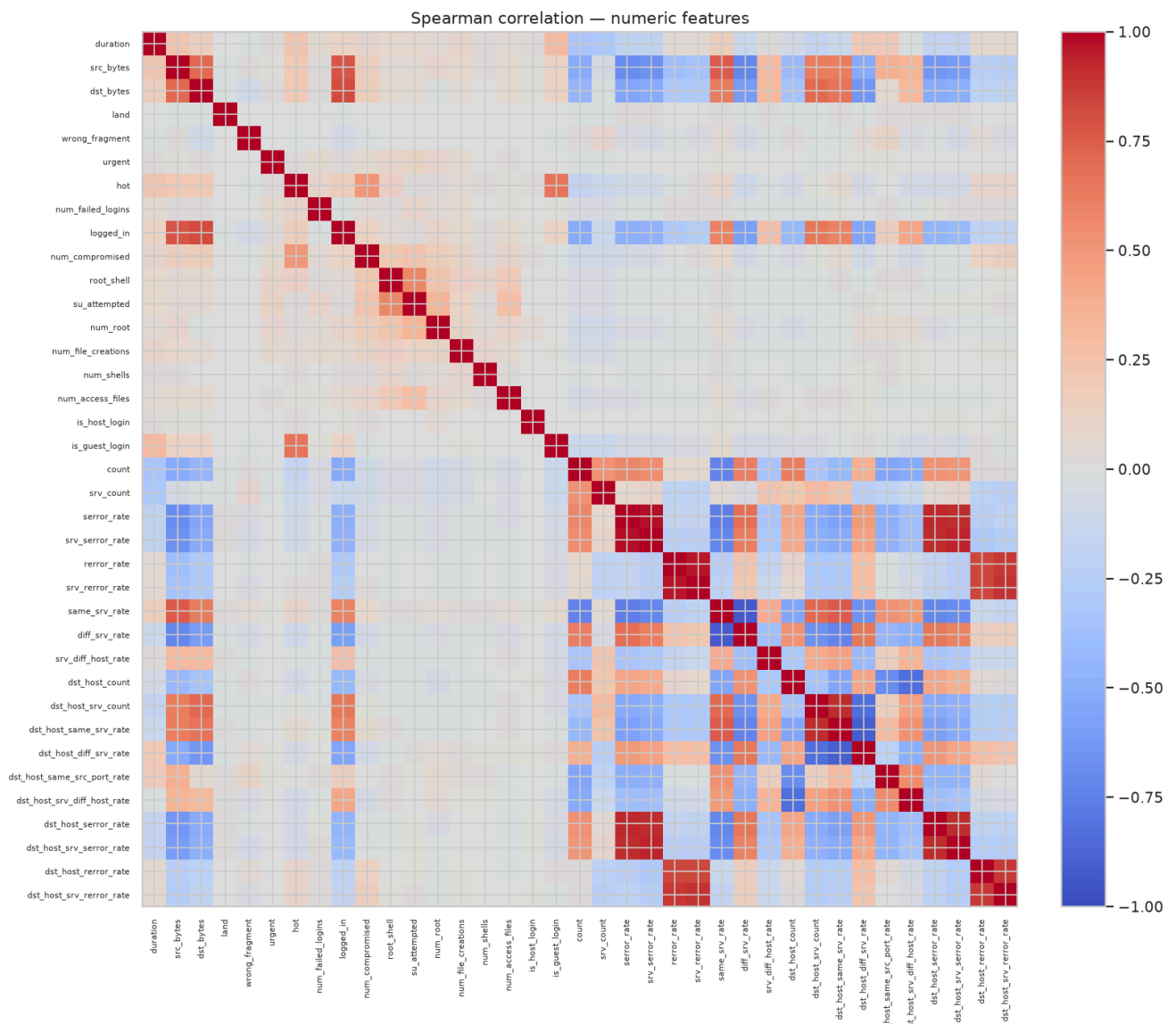
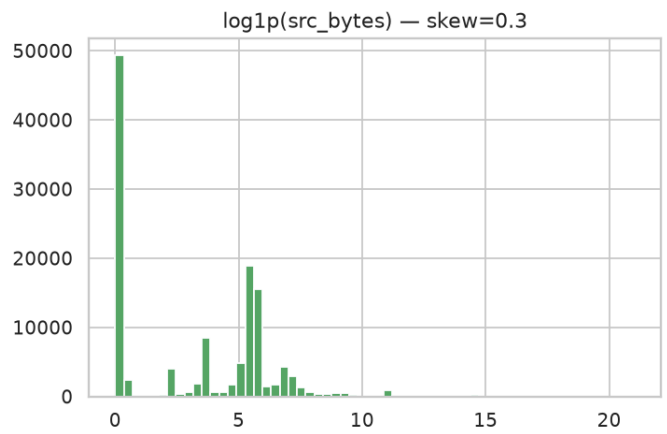
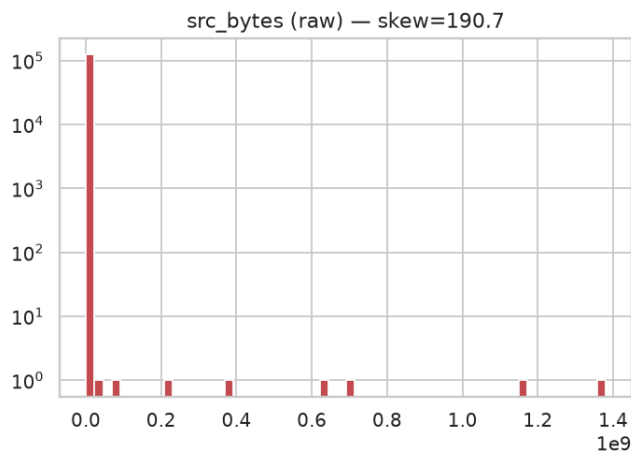
Class	LogReg	Random Forest	Gradient Boosting
normal	0.923	0.974	0.968
DoS	0.796	0.791	0.836
Probe	0.698	0.610	0.672
R2L	0.025	0.050	0.098
U2R	0.119	0.045	0.239

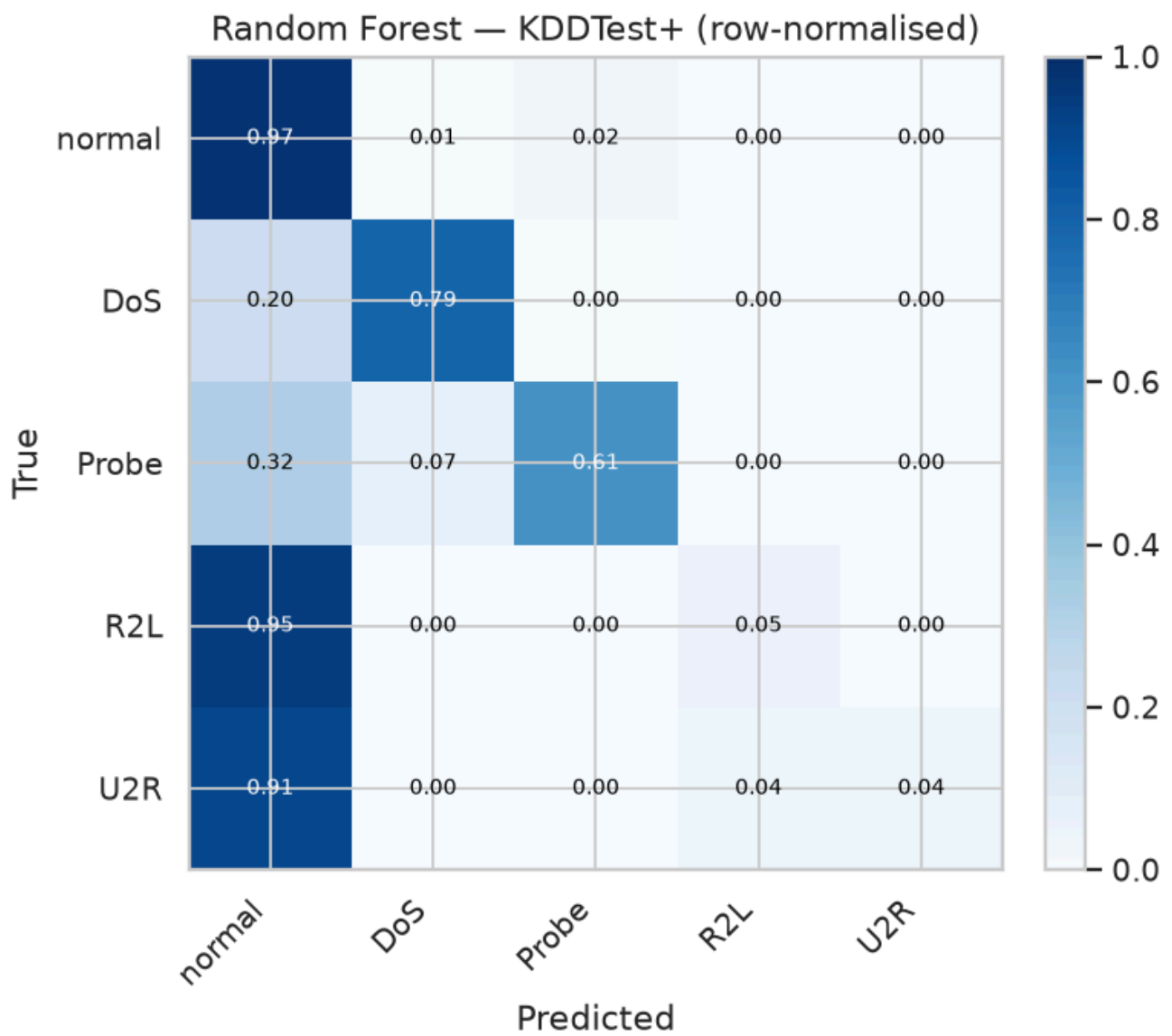
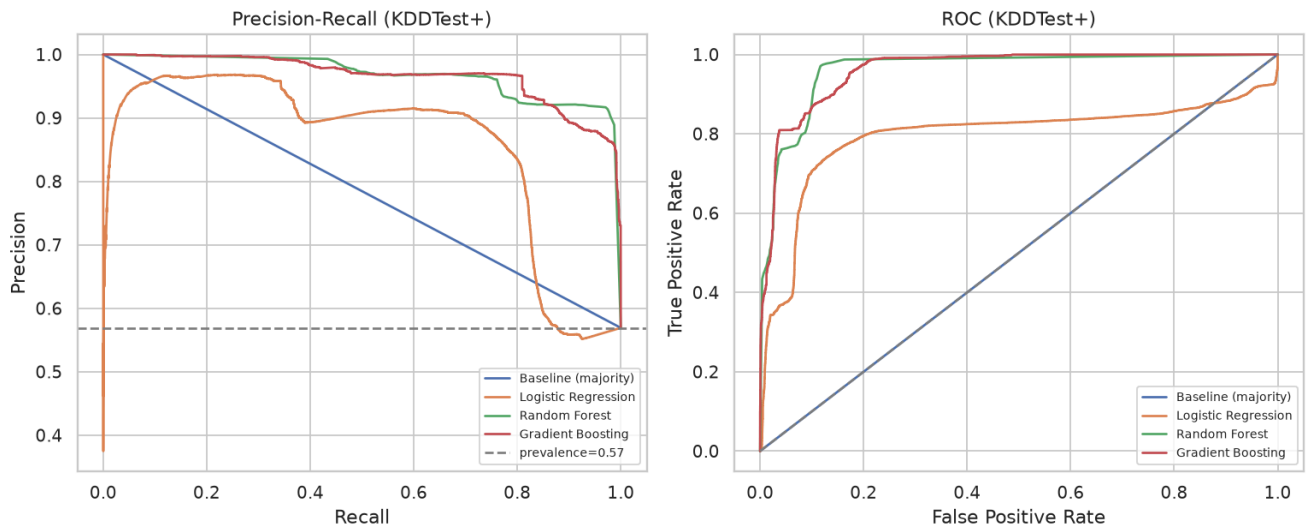
Balanced Accuracy (~0.49–0.56) sits barely above the 0.20 chance level for 5 classes — a fact the 0.78 Accuracy completely hides.

Remediation attempt (cost-sensitive learning). Because the failure is concentrated in the rare classes, we retrained with `class_weight='balanced'`. The effect is **uneven and only partial**: Gradient Boosting's R2L recall improves from 0.098 to **0.277**, but Random Forest's R2L recall actually *drops* (0.050 → 0.016), and **both still miss the large majority of R2L/U2R**. This is strong evidence that the blindness is **not merely an imbalance artefact** — it stems from the train→test shift plus the fact that R2L/U2R are nearly inseparable from normal traffic at the flow-feature level. A real fix needs different telemetry (payload/host features) or a dedicated anomaly-detection paradigm, not just a heavier class weight — a conclusion the original tutorials never reach.

Figures: (1) class balance train vs test; (2) log-transform effect; (3) Spearman heatmap; (4) PR & ROC curves on `KDDTest+`; (5) Random Forest confusion matrix.







6. Error Analysis

Failure examples and patterns. Errors concentrate in **R2L** and **U2R**. The Random Forest confusion matrix (Fig. 5) shows R2L and U2R rows bleeding almost entirely into `normal`. This is the expected failure mode: R2L/U2R are **content/payload** attacks (guessed passwords, buffer overflows) that look statistically like normal connections at the flow level, **and** they are vanishingly rare in training (U2R = 52 of 125,973 rows = 0.04%) yet common in test (R2L = 12.8%).

Cybersecurity implications. The model is **operationally blind to the most damaging intrusions**. A defender trusting the 99% headline would be breached by exactly the credential-theft and privilege-escalation activity an IDS exists to catch.

The FP/FN trade-off. In IDS a missed attack (FN) usually costs more than a false alarm (FP), so we report **F2** (recall-weighted) and sweep the decision threshold:

Threshold	Precision	Recall	F2	False alarms (FP)	Missed attacks (FN)
0.10	0.921	0.852	0.865	935	1,893
0.50	0.969	0.637	0.684	261	4,655
0.90	0.970	0.522	0.575	206	6,132

Lowering the threshold from 0.5 to 0.1 recovers ~2,800 missed attacks at the cost of ~670 extra false alarms — a trade a real SOC must make deliberately. The default 0.5 threshold the tutorials use is **not** the right operating point for a recall-critical task.

7. Executive Summary

We critically reproduced the most common NSL-KDD intrusion-detection tutorial, which advertises **~99% accuracy**. By holding models, features, preprocessing and seeds fixed and changing **only** the evaluation protocol, we reproduced ~0.999 accuracy on a random split of `KDDTrain+` (and 0.9989 under 5-fold CV), then showed the identical Random Forest **falls to 0.78 accuracy on the official KDDTest+** — a 21.9-point drop. The drop is explained by a deliberate **train→test distribution shift** (R2L prevalence 0.79% → 12.8%, U2R 0.04% → 0.30%) and is invisible to Accuracy because of class imbalance: a constant predictor already scores 0.569. Under honest metrics (MCC 0.62, Balanced Accuracy 0.49, PR-AUC) and **per-class recall**, the models detect DoS/Probe but **miss ~95% of R2L and U2R** — the highest-impact attacks. We also found a constant feature (`num_outbound_cmds`), nine redundant feature pairs, and a leakage trap (`difficulty`). **The ~99% claim is not supported** as a measure of real detection capability. The repository contains a fully reproducible notebook, the PDF report, and all figures and metrics.

8. Summing It Up

- **Problem.** Detect network intrusions on NSL-KDD (binary and by attack family).
- **Selected source.** Popular NSL-KDD ML tutorials/repositories reporting ~99% accuracy via a random split of `KDDTrain+` (abhinav-bhardwaj; Mamcose), with the foundational dataset paper by Tavallaee et al. (2009).

- **Dataset.** NSL-KDD — `KDDTrain+` (125,973), `KDDTest+` (22,544), 41 features, 4 attack families.
- **Methodology.** Faithful reproduction + controlled A/B protocol experiment; robust EDA; leakage-safe feature engineering; four models; imbalance-aware metrics; error analysis. Fixed seeds; CV.
- **Main findings of the reproduction study.** The headline accuracy reproduces under the source's protocol but **does not survive correct evaluation** ($\sim 0.99 \rightarrow 0.78$), and the models fail precisely on the rare, dangerous attacks (R2L/U2R recall ≈ 0.05).
- **Were the author's claims supported by our results? No.** The number is arithmetically correct but the *protocol* and *metric choice* make the claim misleading.
- **Most important insight.** In cybersecurity, **the evaluation protocol and the choice of metric decide the conclusion.** A model that looks 99% accurate can be operationally blind to the very attacks it must catch. "*All models are wrong, but some are useful*" — usefulness here means honest evaluation, not a high score.
- **Do we recommend using this project/approach on similar problems? Not as-is.** Recommended practice: evaluate on a distribution-matched / temporally-held-out test set; report MCC/PR-AUC/per-class recall instead of Accuracy; treat R2L/U2R as a rare-class problem (cost-sensitive learning, resampling, or dedicated anomaly detection); and tune the decision threshold to the FP/FN economics of the SOC.
- **Final conclusion.** A rigorous, reproducible **refutation** of an over-optimistic but extremely common cybersecurity-ML claim — demonstrating that methodological rigor, not headline accuracy, is what makes a model trustworthy in cyber defence.

Reproducibility: all numbers above are emitted by `notebooks/analysis.ipynb` into `results/metrics.json`; figures are in `figures/`. Run `python notebooks/analysis.py` or execute the notebook to regenerate. `RANDOM_STATE = 42`.